

PO04 – Modelo Operacional de la Autoridad de Registro (AR)

ID Documento: GOYA-PO04-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Rol	Responsabilidad
Oficial de Seguridad	Redaccion, actualizacion y mantenimiento del documento
Gerente de Operaciones AR	Revision tecnica y validacion de procedimientos
Gerente General	Aprobacion formal y autorizacion de publicacion
Auditor Interno	Verificacion de cumplimiento con normativa aplicable

1.2 Distribucion

Destinatario	Tipo de Copia
Gerencia General	Controlada
Gerente de Operaciones AR	Controlada
Oficial de Seguridad	Controlada
Operadores AR	Controlada
Auditor Interno	Controlada
Entidad Acreditadora (EA-103)	No controlada

1.3 Dependencias documentales

Documento	ID	Relacion
Politica de Certificacion	GOYA-PS01-001	Define politicas que la AR debe cumplir en la verificacion de identidad
Declaracion de Practicas de Certificacion (CPS)	GOYA-CPS-001	Establece procedimientos operativos que la AR implementa
Plan de Seguridad Fisica	GOYA-PS02-001	Controles fisicos aplicables a oficinas AR
Plan de Seguridad Logica	GOYA-PS03-001	Controles de acceso logico a sistemas AR
Plan de Seguridad del Personal	GOYA-PS04-001	Requisitos de personal para operadores AR
Plan de Continuidad del Negocio	GOYA-PS05-001	Procedimientos de continuidad para servicios AR
Plan de Administracion de Llaves	GOYA-PS06-001	Gestion de llaves criptograficas generadas en la AR
Plan de Cese de Actividades	GOYA-PS07-001	Procedimientos de cierre aplicables a la AR
Modelo Operacional AC	GOYA-PO03-001	Interfaz operativa entre AR y AC

2. Resumen Ejecutivo

Goya Ledger SpA opera como Prestador de Servicios de Certificacion (PSC) bajo la legislacion chilena (Ley 19.799) y el marco europeo eIDAS. La Autoridad de Registro (AR) constituye el componente responsable de la verificacion de identidad de los suscriptores previo a la emision de certificados digitales por parte de la Autoridad de Certificacion (AC).

La AR de Goya Ledger implementa un modelo operacional multi-jurisdiccional que soporta verificacion de identidad para las jurisdicciones de Chile, Union Europea y Emiratos Arabes Unidos. El sistema asigna niveles de aseguramiento (LoA) conforme a eIDAS (Low, Substantial, High) segun el metodo de verificacion utilizado y la jurisdiccion del suscriptor.

La infraestructura de la AR opera sobre la misma plataforma que la AC, implementada en Rust sobre Actix-Web 4 con almacenamiento en RocksDB, desplegada en Fly.io (region IAD) con consenso BFT de 4 nodos. La verificacion de identidad remota se realiza mediante integracion con Smart-ID para identificacion electronica, complementada con verificacion presencial en oficinas AR designadas.

El presente documento describe el modelo operacional completo de la AR, incluyendo los servicios prestados, metodos de verificacion, procesos de registro, medidas de seguridad y los procedimientos de entrega segura de llaves privadas conforme al DS 181/2002 Art. 25.

3. Servicios Prestados

3.1 Verificacion de identidad (Identity Proofing)

La AR ejecuta la verificacion de identidad de los suscriptores mediante el modulo `src/identity/ra.rs`. El proceso determina la correspondencia entre la persona fisica y la identidad declarada, registrando el resultado como `ProofingStatus`:

- **Pending**: solicitud recibida, pendiente de verificacion.
- **Verified**: identidad verificada satisfactoriamente.
- **Rejected**: verificacion fallida con motivo de rechazo registrado.

Cada solicitud de verificacion genera un registro `IdentityProofing` que incluye: DID del suscriptor, identificador nacional (RUT para Chile, Emirates ID para EAU), jurisdiccion, nombre legal, metodo de verificacion, nivel de aseguramiento (LoA), marcas temporales y, en caso de rechazo, la razon correspondiente.

3.2 Creacion de identificadores descentralizados (DID)

La AR gestiona la creacion de DIDs para suscriptores verificados a traves de `POST /api/v1/identity`. El formato DID utilizado es `did:goya:{pubkey_hex[..16]}`, derivado canonicamente mediante `identity::did::did_from_pubkey_hex()`. Cada DID se asocia a un `DidDocument` que contiene el hash de clave publica (SHA-256, primeros 128 bits), estado (Active, Revoked, Suspended) y metadatos del suscriptor (nombre, correo electronico, jurisdiccion).

3.3 Captura biometrica

Para verificaciones que requieren nivel de aseguramiento High, la AR captura evidencia biometrica conforme a ISO 19794-2 (minutiae de huella dactilar). La evidencia biometrica se asocia al registro de verificacion y se utiliza exclusivamente para firma electronica avanzada (FEA).

3.4 Asistencia en generacion de llaves del suscriptor

La AR asiste al suscriptor en la generacion de su par de llaves criptograficas. Los algoritmos soportados, definidos en `src/identity/signing.rs` mediante el enum `SigningAlgorithm`, son:

Algoritmo	Tipo	Uso
Ed25519	Clasico	Firma electronica simple (FES)

Algoritmo	Tipo	Uso
ML-DSA-65	Post-cuantico	Firma electronica avanzada (FEA)
SLH-DSA-128s	Post-cuantico	Certificados de larga duracion
RSA	Clasico	Compatibilidad con sistemas legados
ECDSA-P256	Clasico	Interoperabilidad con infraestructura existente

La generacion de llaves se realiza preferentemente en HSM o SSCD del suscriptor mediante la interfaz PKCS#11 (`src/identity/hsm.rs`).

3.5 Reenvio de solicitudes de certificado a la AC

Una vez completada la verificacion de identidad, la AR genera una solicitud de certificado y la transmite a la AC mediante `POST /api/v1/certificates/fea`. La solicitud incluye el resultado de la verificacion, el DID del suscriptor, la clave publica y el nivel de aseguramiento determinado.

3.6 Interrelacion con AC y TSA

La AR opera como componente subordinado a la AC, sin capacidad de emision de certificados. La relacion operativa se rige por GOYA-PO03-001 (Modelo Operacional AC). La AR interactua con la Autoridad de Sellado de Tiempo (TSA) para el sellado temporal de los registros de verificacion de identidad, asegurando la no repudiacion del momento de verificacion.

4. Ubicaciones Operativas

4.1 Infraestructura logica

La AR comparte la infraestructura logica de la AC, desplegada en Fly.io (region IAD, Ashburn, Virginia, EE.UU.):

Componente	Ubicacion	Descripcion
Nodos BFT	Fly.io IAD	4 nodos con consenso HotStuff BFT
Almacenamiento	RocksDB	Registros de identidad y proofing
API AR	Fly.io IAD	Endpoints REST bajo <code>/api/v1/identity/</code>
HSM Virtual	Fly.io IAD	Modulo criptografico para llaves AR

4.2 Oficinas AR para verificacion presencial

Oficina	Direccion	Jurisdiccion	Servicios
Oficina Central Santiago	Por definir	Chile	Verificacion presencial, captura biometrica
Oficina Tallin	Por definir	Union Europea	Verificacion presencial, Smart-ID
Oficina Dubai	Por definir	Emiratos Arabes Unidos	Verificacion presencial, UAE Pass

Las oficinas AR para verificacion presencial cumplen con los requisitos de seguridad fisica establecidos en GOYA-PS02-001. Cada oficina dispone de equipamiento para captura biometrica, verificacion documental y generacion de llaves en SSCD.

5. Tipos de Verificacion de Identidad

5.1 Metodos de verificacion

El modulo `src/identity/ra.rs` define cuatro metodos de verificacion mediante el enum `ProofingMethod`:

Metodo	Descripcion	LoA Resultante	Jurisdicciones
InPerson	Verificacion presencial con documento fisico	High	Chile, EU, UAE
VideoConference	Verificacion remota por videoconferencia con operador AR	Substantial	Chile, EU
RemoteAutomated	Verificacion remota automatizada via Smart-ID	Low	EU (Estonia)
UaePass	Verificacion mediante plataforma UAE Pass	Substantial	UAE

5.2 Niveles de aseguramiento

La funcion `loa_from_method()` determina el nivel de aseguramiento eIDAS segun el metodo:

Nivel eIDAS	Metodos Asociados	Tipos de Certificado Habilitados
High	InPerson	FEA (firma electronica avanzada), certificados cualificados
Substantial	VideoConference, UaePass	FEA con restricciones, certificados avanzados
Low	RemoteAutomated	FES (firma electronica simple), certificados basicos

5.3 Validacion de identificadores nacionales

La AR valida el identificador nacional del suscriptor segun la jurisdiccion:

Jurisdiccion	Identificador	Validacion	Funcion
Chile	RUT	Modulo 11 con digito verificador	<code>validate_rut()</code>
UAE	Emirates ID	15 digitos con verificacion Luhn	<code>validate_emirates_id()</code>
EU	National ID	Delegada al proveedor de identidad (Smart-ID)	<code>validate_national_id()</code>

5.4 Requisitos documentales por metodo

InPerson (presencial): - Documento de identidad vigente con fotografia (cedula de identidad, pasaporte). - Verificacion visual de correspondencia entre persona y documento. - Captura biometrica (huella dactilar, ISO 19794-2). - Copia digitalizada del documento, firmada por el operador AR.

VideoConference: - Documento de identidad mostrado ante camara con resolucion minima 720p. - Verificacion en tiempo real por operador AR certificado. - Grabacion de la sesion con sellado de tiempo. - Validacion NFC del chip del documento cuando este disponible.

RemoteAutomated (Smart-ID): - Autenticacion mediante Smart-ID vinculado a identidad electronica estonia. - Verificacion contra el servicio SK ID Solutions. - Resultado automatizado sin intervencion de operador.

UaePass: - Autenticacion mediante plataforma UAE Pass (ICA). - Verificacion de Emirates ID contra registros gubernamentales. - Nivel de aseguramiento Substantial segun marco nacional UAE.

6. Servicios Externalizados

6.1 Smart-ID (SK ID Solutions)

Aspecto	Detalle
Proveedor	SK ID Solutions AS (Estonia)
Servicio	Verificacion de identidad electronica remota
Implementacion	SmartIdVerifier en src/identity/ra.rs
Interfaz	Trait IdentityVerificationProvider
Jurisdiccion	Union Europea (países bálticos)
LoA resultante	Low (RemoteAutomated)
Modo de prueba	SimulatedIdentityVerifier para desarrollo y testing

El contrato con SK ID Solutions contempla: - SLA de disponibilidad del 99.5% mensual. - Tiempo de respuesta máximo de 30 segundos por verificación. - Protección de datos conforme a GDPR. - Notificación de incidentes de seguridad en un plazo máximo de 24 horas. - Auditorías anuales del proveedor accesibles al PSC.

6.2 Fly.io (Infraestructura como Servicio)

Aspecto	Detalle
Proveedor	Fly.io Inc. (EE.UU.)
Servicio	IaaS para despliegue de nodos
Region	IAD (Ashburn, Virginia)
Certificaciones	SOC 2 Type II
Uso	Hospedaje de nodos BFT, API, almacenamiento RocksDB

La externalización de infraestructura no incluye acceso del proveedor a datos de suscriptores ni a material criptográfico. Las llaves privadas de la AR residen exclusivamente en HSM bajo control del PSC.

7. Protección de Activos

7.1 Datos personales del suscriptor (PII)

Los datos personales recopilados durante la verificación de identidad se clasifican y protegen según la siguiente tabla:

Dato	Clasificacion	Cifrado en Reposo	Cifrado en Transito	Retencion
Nombre legal	Confidencial	AES-256-GCM	TLS 1.3	Vigencia certificado + 10 años
RUT / National ID	Confidencial	AES-256-GCM	TLS 1.3	Vigencia certificado + 10 años
Correo electronico	Interno	AES-256-GCM	TLS 1.3	Vigencia certificado + 1 año
Direccion fisica	Confidencial	AES-256-GCM	TLS 1.3	Vigencia certificado + 10 años
Copia documento identidad	Restringido	AES-256-GCM	TLS 1.3	90 días post-verificacion

7.2 Datos biometricos

La evidencia biometrica (minutiae de huella dactilar conforme a ISO 19794-2) recibe tratamiento especial:

- Cifrado en reposo con clave derivada de HSM, independiente de la clave de datos generales.
- Acceso restringido exclusivamente a operadores AR con rol autorizado.
- Eliminacion automatica a los 30 días posteriores a la emision del certificado.
- Prohibicion de uso para fines distintos a la verificacion de identidad del suscriptor.
- Registro de cada acceso en el log de auditoria (AuditAction::BiometricAccessed).

7.3 Canales seguros para entrega de llaves

La entrega de material criptografico al suscriptor se realiza exclusivamente mediante:

- Entrega presencial del SSCD con PIN en sobre sellado separado.
- Canal TLS 1.3 con autenticacion mutua (mTLS) para activacion remota.
- Separacion obligatoria entre dispositivo criptografico y datos de activacion.

8. Componentes del Sistema

8.1 Interfaces AR-AC

La comunicacion entre la AR y la AC se realiza mediante API REST interna con autenticacion mutua TLS:

Endpoint	Metodo	Descripcion	Direccion
/api/v1/identity/proof	POST	Envio de solicitud de verificacion	AR interno
/api/v1/identity/proof/{did}/approve	POST	Aprobacion por operador AR	AR interno
/api/v1/identity/proof/{did}/reject	POST	Rechazo con motivo	AR interno
/api/v1/identity/proof/{did}	GET	Consulta de estado de verificacion	AR -> AC
/api/v1/identity/verify	POST	Verificacion automatizada (Smart-ID)	AR -> Proveedor externo
/api/v1/certificates/fea	POST	Solicitud de certificado FEA	AR -> AC
/api/v1/identity	POST	Creacion de DID	AR interno
/api/v1/identity/{did}	GET	Consulta de documento DID	AR / AC

La interfaz AR-AC implementa: - Autenticacion mutua TLS (mTLS) con certificados emitidos por la AC raiz. - Validacion de estado de verificacion previo a emision de certificado. - Timeout de solicitudes configurable via HTTP_REQUEST_TIMEOUT_SECS. - Reintentos automaticos con backoff exponencial ante fallos transitorios.

8.2 Elementos de seguridad

Elemento	Implementacion	Proposito
TLS 1.3	Certificados AC raiz	Cifrado de comunicaciones AR-AC y AR-suscriptor
mTLS	Certificados mutuos AR-AC	Autenticacion bidireccional entre componentes
Cifrado PII	AES-256-GCM via pqc_crypto_module	Proteccion de datos personales en reposo
Cifrado biometrico	Clave derivada de HSM	Proteccion de evidencia biometrica
Firma de registros	Ed25519 / ML-DSA-65	Integridad de registros de verificacion

Elemento	Implementacion	Proposito
Hash-chain auditoria	SHA-256 encadenado	Deteccion de alteraciones en log de auditoria

8.3 Administracion

Rol	Responsabilidades	Separacion
Administrador AR	Configuracion de parametros AR, gestion de operadores, mantenimiento de integraciones	No puede operar como Administrador AC
Operador AR	Verificacion presencial de identidad, aprobacion/rechazo de solicitudes, captura biometrica	No puede aprobar sus propias solicitudes
Oficial de Seguridad	Auditoria de operaciones AR, gestion de incidentes, revision de logs	Independiente de operaciones AR y AC
Administrador AC	Emision de certificados, gestion de CRL	No puede operar como Administrador AR

El control de acceso se implementa mediante `enforce_acl` en la capa API, configurable via `ACL_MODE`. En produccion (`RUST_BC_ENV=production`), el modo `permissive` genera advertencias y se requiere configuracion explicita de roles.

8.4 Directorio y repositorio

Los registros de identidad de suscriptores se almacenan en RocksDB con la siguiente estructura:

Almacen	Clave	Contenido
Identity Store	<code>{height:012}:{did}</code>	IdentityRecord con clave publica, metadatos, estado
Proofing Store	<code>{did}</code>	IdentityProofing con resultado de verificacion
DID Registry	<code>{did}</code>	DidDocument con estado y credenciales
Biometric Store	<code>{did}:{timestamp}</code>	Evidencia biometrica cifrada

El directorio soporta consultas mediante: - GET `/api/v1/store/identities/{did}`: consulta individual con control de acceso ACL. - GET `/api/v1/store/identities`: listado paginado de registros. - GET `/api/v1/identity/{did}`: consulta de documento DID.

8.5 Auditoria y respaldo

El sistema de auditoria de la AR utiliza `src/audit.rs` con los siguientes eventos especificos:

Evento	AuditAction	Descripcion
Registro de DID	DidRegistered	Creacion de nuevo DID para suscriptor
Revocacion de DID	DidRevoked	Revocacion de DID existente
Solicitud de verificacion	IdentityProofingSubmitted	Recepcion de solicitud de identity proofing
Aprobacion de identidad	IdentityProofingApproved	Verificacion exitosa por operador AR
Rechazo de identidad	IdentityProofingRejected	Verificacion fallida con motivo
Generacion de llave	KeyGenerated	Generacion de par de llaves del suscriptor
Activacion de llave	KeyActivated	Activacion de llave en dispositivo del suscriptor

Cada AuditEntry incluye: marca temporal, accion, metodo HTTP, ruta, organizacion, IP de origen, codigo de estado, trace ID, duracion y metadatos adicionales. Los entres se encadenan mediante SHA-256 (previous_hash -> entry_hash) para deteccion de alteraciones.

El respaldo de registros de identidad se realiza conforme a GOYA-PS05-001: - Respaldo incremental diario de RocksDB. - Respaldo completo semanal con cifrado AES-256-GCM. - Almacenamiento de respaldos en ubicacion geograficamente separada. - Pruebas de restauracion trimestrales.

8.6 Bases de datos

Base de Datos	Motor	Contenido	Cifrado
Identity Store	RocksDB	Registros de identidad, claves publicas, metadatos	AES-256-GCM
Proofing Records	RocksDB	Resultados de verificacion, estados, timestamps	AES-256-GCM
DID Mappings	RocksDB	Documentos DID, estado, credenciales asociadas	AES-256-GCM
Audit Log	RocksDB	Log encadenado de auditoria	Integridad SHA-256
Biometric Store	RocksDB	Evidencia biometrica ISO 19794-2	Clave HSM dedicada

Cuando STORAGE_BACKEND=rocksdb, todos los almacenes persisten en disco con las claves RocksDB formateadas como {height:012}:{id} (cero-padded 12 digitos). En modo desarrollo, MemoryStore proporciona almacenamiento volatil para pruebas.

8.7 Privacidad

La AR cumple con las siguientes normativas de proteccion de datos:

Normativa	Jurisdiccion	Requisitos Implementados
Ley 19.628	Chile	Consentimiento informado, acceso, rectificacion, cancelacion
GDPR	Union Europea	Minimizacion de datos, derecho al olvido, portabilidad, DPO
Ley de Proteccion de Datos Personales UAE	Emiratos Arabes Unidos	Consentimiento, limitacion de proposito, seguridad

Principios de privacidad implementados:

- **Minimizacion:** la AR recopila exclusivamente los datos necesarios para la verificacion de identidad y emision del certificado.
- **Limitacion de proposito:** los datos se utilizan unicamente para identity proofing y emision de certificados.
- **Derecho de acceso:** el suscriptor puede consultar sus datos mediante GET / api/v1/identity/{did} previa autenticacion.
- **Derecho de supresion:** eliminacion de datos personales tras vencimiento del periodo de retencion, con excepcion de los registros de auditoria que se retienen por obligacion legal.
- **Retencion limitada:** los datos biometricos se eliminan a los 30 dias post-emision; las copias de documentos a los 90 dias; los datos de identidad se retienen durante la vigencia del certificado mas 10 anos conforme a normativa.

8.8 Capacitacion del personal

Los operadores AR deben completar el siguiente programa de capacitacion antes de operar:

Modulo	Duracion	Contenido	Frecuencia
Verificacion documental	16 horas	Deteccion de documentos falsificados, verificacion de elementos de seguridad, procedimientos por jurisdiccion	Inicial + recertificacion anual
Deteccion de fraude	8 horas	Suplantacion de identidad, ingenieria social, documentos alterados digitalmente	Inicial + recertificacion anual
	8 horas		

Modulo	Duracion	Contenido	Frecuencia
Captura biometrica	8 horas	Operacion de equipo biometrico, ISO 19794-2, calidad de captura	Inicial + recertificacion bianual
Proteccion de datos		Ley 19.628, GDPR, manejo de PII, procedimientos de destruccion	Inicial + recertificacion anual
Operacion del sistema	16 horas	Uso de endpoints AR, flujo de verificacion, manejo de HSM, procedimientos de escalamiento	Inicial + actualizacion por cambio de version
Seguridad de la informacion	8 horas	GOYA-PS03-001, GOYA-PS04-001, gestion de incidentes, reporte de vulnerabilidades	Inicial + recertificacion anual

La recertificacion incluye evaluacion practica con escenarios de fraude simulados. Los operadores que no aprueben la recertificacion son suspendidos hasta completar capacitacion adicional.

9. Proceso de Registro

9.1 Flujo completo de registro

El proceso de registro de un suscriptor sigue el siguiente flujo secuencial:

Paso 1 – Solicitud del suscriptor El suscriptor inicia el proceso de registro proporcionando sus datos personales y seleccionando el tipo de certificado requerido (FES o FEA). El sistema registra la solicitud con `ProofingStatus::Pending`.

Paso 2 – Validacion de identificador nacional El sistema valida automaticamente el identificador nacional segun la jurisdiccion: - Chile: validacion de RUT mediante `validate_rut()` (modulo 11). - UAE: validacion de Emirates ID mediante `validate_emirates_id()` (15 digitos, Luhn). - EU: validacion delegada al proveedor de identidad electronica.

Paso 3 – Verificacion de identidad (Identity Proofing) Segun el metodo seleccionado: - **InPerson**: el suscriptor se presenta en oficina AR con documento de identidad vigente. El operador AR verifica visualmente la correspondencia, valida los elementos de seguridad del documento y registra la verificacion. - **VideoConference**: sesion de video en tiempo real con operador AR certificado. El suscriptor muestra su documento ante la camara. La sesion se graba con sellado de tiempo. - **RemoteAutomated**: verificacion automatica via `POST /api/v1/`

identity/verify utilizando SmartIdVerifier. El resultado se registra automaticamente. - **UaePass**: verificacion mediante la plataforma UAE Pass con resultado automatizado.

Paso 4 – Captura biometrica (LoA High) Para certificados que requieren nivel de aseguramiento High (InPerson), se captura la huella dactilar del suscriptor conforme a ISO 19794-2. La evidencia biometrica se cifra y almacena con clave derivada de HSM.

Paso 5 – Creacion del DID Tras la verificacion exitosa, el sistema crea el DID del suscriptor mediante POST /api/v1/identity. El DID se genera canonicamente como did:goya:{pubkey_hex[.16]} usando did_from_pubkey_hex(). Se crea el DidDocument asociado con estado Active.

Paso 6 – Generacion del par de llaves El par de llaves del suscriptor se genera segun el tipo de certificado: - FES: Ed25519 mediante SoftwareSigningProvider. - FEA: ML-DSA-65 mediante MlDsaSigningProvider o en HSM via HsmSigningProvider (PKCS#11).

La generacion en HSM utiliza la configuracion de HsmConfig::from_env() con las variables HSM_PKCS11_LIB, HSM_SLOT_ID, HSM_PIN, HSM_KEY_LABEL, HSM_KEY_ALGORITHM.

Paso 7 – Solicitud de certificado a la AC La AR envia la solicitud de certificado a la AC mediante POST /api/v1/certificates/fea, incluyendo: DID del suscriptor, clave publica, resultado de verificacion y nivel de aseguramiento. La AC valida la solicitud contra la politica de certificacion (GOYA-PS01-001) y emite el certificado.

Paso 8 – Entrega al suscriptor El certificado emitido y el dispositivo criptografico (SSCD) se entregan al suscriptor conforme a los procedimientos de la Seccion 14. El suscriptor firma el acta de aceptacion del certificado.

9.2 Tiempos de procesamiento

Metodo de Verificacion	Tiempo Maximo	SLA
InPerson	24 horas desde la cita	95% dentro de plazo
VideoConference	48 horas desde solicitud	90% dentro de plazo
RemoteAutomated	5 minutos	99% dentro de plazo
UaePass	10 minutos	98% dentro de plazo

10. Plan de Auditoria

10.1 Auditorias internas

Tipo	Frecuencia	Alcance	Responsable
	Mensual	Muestra aleatoria del	Oficial de Seguridad

Tipo	Frecuencia	Alcance	Responsable
Revision de logs de verificacion		10% de verificaciones del periodo	
Auditoria de calidad de proofing	Trimestral	Revision de procedimientos de verificacion presencial, incluyendo observacion in situ	Auditor Interno
Auditoria de acceso a datos	Trimestral	Revision de accesos a PII y datos biometricos	Oficial de Seguridad
Auditoria de integridad de logs	Mensual	Verificacion de cadena SHA-256 del audit log	Sistema automatizado
Revision de privilegios de operadores	Semestral	Validacion de roles y permisos asignados vs. requeridos	Administrador AR

10.2 Auditorias externas

Tipo	Frecuencia	Alcance	Ejecutor
Auditoria de cumplimiento EA-103	Anual	Cumplimiento integral del modelo operacional AR con requisitos de acreditacion	Auditor externo acreditado
Auditoria de proteccion de datos	Anual	Cumplimiento con Ley 19.628 / GDPR segun jurisdicciones operativas	Auditor de privacidad independiente
Pruebas de penetracion	Anual	Seguridad de interfaces AR, endpoints de verificacion, almacenamiento de PII	Empresa de seguridad externa

10.3 Verificaciones de muestra

El Oficial de Seguridad realiza verificaciones de muestra mensuales que incluyen: - Seleccion aleatoria de 10 verificaciones completadas en el periodo. - Validacion de que el procedimiento documentado se siguio correctamente. - Verificacion de que la documentacion de soporte esta completa. - Confirmacion de que el nivel de aseguramiento asignado corresponde al metodo utilizado. - Registro de hallazgos y acciones correctivas en el sistema de gestion de calidad.

11. Seguridad Fisica

11.1 Oficinas AR para verificacion presencial

Las oficinas AR donde se realiza verificacion presencial cumplen con los requisitos de GOYA-PS02-001 y adicionalmente:

Control	Implementacion
Control de acceso	Tarjeta de proximidad + PIN para acceso a areas de verificacion
Vigilancia	CCTV con grabacion continua, retencion minima 90 dias
Area de verificacion	Sala dedicada con privacidad visual y acustica
Almacenamiento de documentos	Caja fuerte con doble cerradura para copias temporales de documentos
Destruccion de documentos	Destruccion de corte cruzado (DIN 66399 nivel P-4) para copias fisicas
Registro de visitantes	Libro de registro con hora de entrada y salida del suscriptor
Alarma	Sistema de alarma con monitoreo 24/7 y respuesta armada

11.2 Manejo seguro de documentos

- Las copias de documentos de identidad se digitalizan inmediatamente y se destruyen fisicamente al finalizar la sesion de verificacion.
 - Los documentos digitalizados se cifran antes de almacenarse y se eliminan automaticamente a los 90 dias.
 - Los equipos de captura biometrica se almacenan en area segura fuera del horario de operacion.
 - Las estaciones de trabajo de verificacion no tienen dispositivos de almacenamiento removible.
-

12. Seguridad del Personal

12.1 Verificacion de antecedentes

Todos los operadores AR son sometidos a verificacion de antecedentes antes de su designacion:

Verificacion	Periodicidad	Responsable
Antecedentes penales	Previo a contratacion + anual	Recursos Humanos
Antecedentes comerciales	Previo a contratacion + anual	Recursos Humanos
Referencias laborales	Previo a contratacion	Recursos Humanos
Verificacion de identidad del operador	Previo a contratacion	Oficial de Seguridad
Evaluacion de conflictos de interes	Previo a contratacion + semestral	Oficial de Seguridad

12.2 Acuerdos de confidencialidad

Todo el personal AR firma los siguientes acuerdos: - Acuerdo de no divulgacion (NDA) que cubre datos de suscriptores y operaciones AR. - Compromiso de cumplimiento de politicas de seguridad (GOYA-PS04-001). - Declaracion de conflictos de interes. - Aceptacion de la politica de uso aceptable de sistemas.

12.3 Control dual

Las siguientes operaciones requieren participacion de dos personas autorizadas:

Operacion	Roles Requeridos
Aprobacion de verificacion de identidad para LoA High	Operador AR + Supervisor AR
Acceso a datos biometricos almacenados	Operador AR + Oficial de Seguridad
Modificacion de parametros de configuracion AR	Administrador AR + Oficial de Seguridad
Restauracion de respaldos de datos de identidad	Administrador AR + Gerente de Operaciones
Revocacion masiva de DIDs	Administrador AR + Gerente General

13. Seguridad del Modulo Criptografico

13.1 HSM para llaves de la AR

Las llaves criptograficas de la AR (firma de registros de verificacion, cifrado de datos PII) se almacenan exclusivamente en HSM conforme a FIPS 140-2 Nivel 3 o superior:

Parametro	Configuracion
Interfaz	PKCS#11 via <code>src/identity/hsm.rs</code>
Biblioteca	Configurable via <code>HSM_PKCS11_LIB</code>
Slot	Configurable via <code>HSM_SLOT_ID</code>
Autenticacion	PIN de operador via <code>HSM_PIN</code>
Etiqueta de llave	Configurable via <code>HSM_KEY_LABEL</code>
Algoritmo	Configurable via <code>HSM_KEY_ALGORITHM</code> (Ed25519, ML-DSA-65)

El acceso al HSM se implementa mediante `HsmSigningProvider::new()` que inicializa la sesion PKCS#11, autentica con el PIN del operador y localiza la llave por etiqueta. Los errores se clasifican en `HsmError: LibraryNotFound`, `SlotNotFound`, `AuthFailed`, `KeyNotFound`, `SignFailed`, `NotEnabled`.

13.2 Generacion de llaves del suscriptor en HSM/SSCD

Para certificados FEA (LoA High y Substantial), la generacion del par de llaves del suscriptor se realiza en:

Dispositivo	Nivel	Requisito
HSM centralizado del PSC	FIPS 140-2 Nivel 3	Llaves de firma FEA gestionadas por el PSC
SSCD del suscriptor	Common Criteria EAL4+	Llaves de firma FEA bajo control exclusivo del suscriptor
Software (SoftwareSigningProvider)	N/A	Solo para certificados FES (LoA Low)

La clave privada del suscriptor nunca se transmite en texto claro fuera del modulo criptografico donde fue generada.

14. Entrega Segura de Llaves Privadas

Conforme al DS 181/2002 Art. 25, la AR implementa los siguientes procedimientos para la entrega segura de llaves privadas a los suscriptores.

14.1 Requisitos del SSCD

El dispositivo seguro de creacion de firma (SSCD) utilizado para almacenar la llave privada del suscriptor debe cumplir:

- Certificacion Common Criteria EAL4+ o FIPS 140-2 Nivel 2 como minimo.
- Proteccion contra extraccion de la llave privada del dispositivo.
- Mecanismo de autenticacion del titular (PIN, biometrico o ambos).
- Contador de intentos fallidos con bloqueo automatico tras 5 intentos.
- Resistencia a ataques de canal lateral documentada por el fabricante.

14.2 Procedimiento de entrega presencial

1. El operador AR verifica la identidad del suscriptor (mismo procedimiento que la verificacion inicial).
2. El SSCD se entrega en sobre sellado con sello de seguridad numerado.
3. El PIN inicial se entrega en sobre separado, sellado e independiente.
4. El PUK de desbloqueo se entrega en un tercer sobre, separado de PIN y dispositivo.
5. El suscriptor firma el acta de recepcion que detalla: numero de serie del SSCD, numero de sello de seguridad, fecha y hora de entrega, identificacion del operador AR.
6. El operador AR verifica que el suscriptor active el SSCD y cambie el PIN inicial antes de abandonar la oficina AR.
7. Los sobres de entrega se destruyen inmediatamente despues de la activacion.

14.3 Procedimiento de entrega remota

Para jurisdicciones donde la entrega remota esta permitida (LoA Substantial):

1. El SSCD se envia por servicio de mensajeria certificada con acuse de recibo.
2. El PIN de activacion se envia por canal independiente (SMS cifrado o correo electronico cifrado).
3. El PUK se envia por un tercer canal independiente.
4. El suscriptor debe activar el SSCD dentro de las 72 horas siguientes a la recepcion.
5. La activacion requiere autenticacion del suscriptor mediante el metodo de verificacion original.
6. Si el SSCD no se activa en el plazo establecido, se revoca automaticamente.

14.4 Proteccion de datos de activacion

Dato	Proteccion	Retencion
PIN inicial	Generado aleatoriamente, no almacenado por la AR	Destruido tras cambio por suscriptor
PUK	Cifrado en HSM, accesible solo para desbloqueo	Vigencia del certificado
Codigo de activacion remota	Token de uso unico, expiracion 72 horas	Eliminado tras uso o expiracion

14.5 Acuse de recibo del suscriptor

El suscriptor debe confirmar formalmente: - Recepcion del SSCD en condiciones integras (sellos sin violar). - Cambio exitoso del PIN inicial. - Comprension de sus obligaciones de custodia del SSCD y confidencialidad del PIN. - Aceptacion de los terminos del contrato de suscriptor. - Conocimiento del procedimiento de revocacion en caso de compromiso.

El acta de aceptacion se registra en el sistema con `AuditAction::KeyActivated` y se asocia al DID del suscriptor.

15. Confiabilidad de Dispositivos

Conforme al DS 181/2002 Art. 25, la AR verifica la confiabilidad de los dispositivos criptograficos utilizados por los suscriptores.

15.1 Requisitos de certificacion

Tipo de Dispositivo	Certificacion Minima	Validez	Aplicabilidad
SSCD para firma FEA	Common Criteria EAL4+ (EN 419211)	Segun certificacion del fabricante	Obligatorio para LoA High
Token criptografico USB	FIPS 140-2 Nivel 2	Segun certificacion NIST	Aceptable para LoA Substantial
Tarjeta inteligente	Common Criteria EAL4+ (ISO 15408)	Segun certificacion del fabricante	Obligatorio para LoA High
HSM de red	FIPS 140-2 Nivel 3	Segun certificacion NIST	Generacion centralizada de llaves FEA

15.2 Criterios de evaluacion

La AR verifica los siguientes criterios antes de aprobar un modelo de dispositivo:

- Certificacion vigente emitida por laboratorio acreditado.
- Soporte para los algoritmos requeridos por el PSC (`SigningAlgorithm: Ed25519, ML-DSA-65`).
- Interfaz PKCS#11 compatible con `HsmSigningProvider`.
- Proteccion contra clonacion y extraccion de llaves.
- Mecanismo de destruccion segura de llaves (key zeroization).
- Historial de vulnerabilidades del fabricante y tiempo de respuesta a parches.

15.3 Gestion del ciclo de vida de dispositivos

Fase	Procedimiento	Registro
Adquisicion	Compra a proveedor certificado, verificacion de certificaciones	Inventario de dispositivos
Inicializacion	Configuracion en ambiente seguro, carga de perfil criptografico	AuditAction::KeyGenerated
Asignacion	Vinculacion a suscriptor, entrega conforme Seccion 14	AuditAction::KeyActivated
Operacion	Monitoreo de estado, actualizaciones de firmware cuando aplique	Log de operaciones
Suspension	Bloqueo temporal por solicitud del suscriptor o incidente	AuditAction::KeyDeactivated
Revocacion	Invalidacion permanente, solicitud de devolucion del dispositivo	AuditAction::KeyDestroyed
Destruccion	Zeroization de llaves, destruccion fisica del dispositivo	Acta de destruccion firmada

15.4 Dispositivos no aprobados

La AR mantiene una lista de dispositivos no aprobados que incluye modelos con:

- Certificaciones expiradas sin renovacion.
- Vulnerabilidades conocidas sin parche disponible.
- Algoritmos criptograficos deprecados sin soporte para los requeridos.
- Fabricantes que no proporcionan soporte o actualizaciones de seguridad.

Los suscriptores con dispositivos en esta lista son notificados y se inicia el proceso de migracion a un dispositivo aprobado.

16. Modelo de Uso de Llave Privada

16.1 Restricciones de uso

Las llaves privadas de los suscriptores estan sujetas a las siguientes restricciones de uso, definidas en el perfil del certificado emitido por la AC:

Tipo de Certificado	Key Usage	Extended Key Usage	Restriccion
FES (firma simple)	digitalSignature	id-kp-emailProtection	Solo firma de documentos y correo

Tipo de Certificado	Key Usage	Extended Key Usage	Restriccion
FEA (firma avanzada)	digitalSignature, nonRepudiation	id-kp-emailProtection, id-kp-documentSigning	Firma con valor legal, no repudio
Cifrado	keyEncipherment, dataEncipherment	id-kp-emailProtection	Solo cifrado, nunca firma
Autenticacion	digitalSignature	id-kp-clientAuth	Solo autenticacion TLS cliente

16.2 Politica de custodia de llaves (Key Escrow)

Tipo de Llave	Custodia (Escrow)	Justificacion
Llaves de firma (FES/FEA)	Prohibido	La custodia de llaves de firma invalida la propiedad de no repudio. Conforme a Ley 19.799 Art. 15, la llave privada de firma debe estar bajo control exclusivo del titular
Llaves de cifrado	Permitido con consentimiento	Recuperacion de datos cifrados en caso de perdida de llave. Custodia en HSM del PSC con acceso bajo control dual

16.3 Politica de respaldo de llaves

Tipo de Llave	Respaldo	Procedimiento
Llaves de firma del suscriptor	Prohibido	No se respaldan. En caso de perdida, se emite nuevo certificado previo nuevo identity proofing
Llaves de cifrado del suscriptor	Permitido	Respaldo cifrado en HSM del PSC, acceso bajo control dual, registrado como AuditAction::KeyBackedUp
Llaves de la AR	Obligatorio	Respaldo en HSM secundario con ceremonia de llaves documentada, restauracion registrada como AuditAction::KeyRestored

16.4 Obligaciones del suscriptor

El suscriptor se compromete a: - Mantener la confidencialidad de su PIN y datos de activación. - No compartir, prestar o ceder el SSCD a terceros. - Notificar a la AR dentro de las 24 horas siguientes al descubrimiento de compromiso o pérdida del SSCD. - Utilizar la llave privada exclusivamente para los fines establecidos en el certificado. - Revocar el certificado antes de cualquier cambio en los datos contenidos en el mismo.

El incumplimiento de estas obligaciones libera al PSC de responsabilidad conforme al contrato de suscriptor y a la Ley 19.799 Art. 15.

17. Referencias

17.1 Normativa legal

Referencia	Descripción
Ley 19.799 (Chile)	Ley sobre documentos electrónicos, firma electrónica y servicios de certificación
Ley 19.799 Art. 15	Obligaciones del titular del certificado
DS 181/2002 (Chile)	Reglamento de la Ley 19.799
DS 181/2002 Art. 25	Requisitos de entrega segura de dispositivos y llaves privadas
Ley 19.628 (Chile)	Protección de la vida privada (datos personales)
Reglamento (UE) 910/2014 (eIDAS)	Identificación electrónica y servicios de confianza
eIDAS Art. 24	Requisitos para prestadores cualificados de servicios de confianza
GDPR (UE) 2016/679	Reglamento general de protección de datos

17.2 Normas técnicas

Referencia	Descripción
FIPS 140-2	Requisitos de seguridad para módulos criptográficos
ISO 19794-2	Formato de datos biométricos – minutiae de huella dactilar
ISO 15408 (Common Criteria)	Criterios de evaluación de seguridad para tecnología de información
EN 419211	Requisitos de seguridad para dispositivos de creación de firma
DIN 66399	Destrucción de soportes de datos

Referencia	Descripcion
NIST FIPS 204 (ML-DSA)	Esquema de firma digital basado en lattices

17.3 Documentos internos

Referencia	ID	Descripcion
Politica de Certificacion	GOYA-PS01-001	Politica de certificacion del PSC
Plan de Seguridad Fisica	GOYA-PS02-001	Controles de seguridad fisica
Plan de Seguridad Logica	GOYA-PS03-001	Controles de acceso logico
Plan de Seguridad del Personal	GOYA-PS04-001	Requisitos de personal
Plan de Continuidad	GOYA-PS05-001	Continuidad del negocio
Plan de Administracion de Llaves	GOYA-PS06-001	Gestion de llaves criptograficas
Plan de Cese de Actividades	GOYA-PS07-001	Procedimientos de cese
Modelo Operacional AC	GOYA-PO03-001	Modelo operacional de la Autoridad de Certificacion
Declaracion de Practicas (CPS)	GOYA-CPS-001	Declaracion de practicas de certificacion